If all conditions are satisfied, ACME grants Angela limited access to view the relevant logs during her audit. No account setup is necessary, and no lingering access remains after the contract ends. This approach also makes it easy for AuditsRUs to assign additional auditors to the project or replace Angela if circumstances change, without creating new accounts or coordinating manual onboarding steps with ACME. The verifiable credentials provide the context ACME needs to make a confident authorization decision without directly managing the identities of external personnel.

16.3 Trusting credential issuers

Verifiable credentials give ACME a way to incorporate authoritative external claims into policy decisions, but only if ACME trusts the issuers of those claims. Trust is not established by the holder or by cryptography. As discussed in chapter 2, cryptography gives ACME confidence that a credential is genuine and unaltered, but trust is based on the authority behind the claim. ACME must evaluate whether an issuer is qualified to make a particular type of claim and whether the issuer operates within a governance framework that ACME considers trustworthy.

Figure 16.2 shows the trust diamond, which extends the trust triangle introduced in figure 16.1. Along with the holder, issuer, and verifier, the diamond adds a governance authority that defines the processes for evaluating issuers and the criteria they must meet to participate. As we discussed in chapter 14, governance is the foundation of trust. The governance authority publishes a governance framework that documents its governance processes and decisions. Verifiers use the framework to understand how issuers are vetted, supervised, and held accountable.

In our example, NISA fulfills this role. NISA establishes the requirements for becoming an accredited security auditor, evaluates and certifies organizations that meet its standards, and documents the procedures for issuing, renewing, suspending, or revoking accreditations. ACME relies on this framework to determine whether a credential issuer is accredited by NISA and can be trusted.